Quantum Bill of Materials

Acme Corp

Generated 2026-09-27T05:53:25.823413+00:00 · catalog v1 (5a06fc0a9f41...)

Readiness summary

Total crypto findings	39 across 18 distinct algorithms/protocols
Quantum-safe today (PQ_SAFE + HYBRID)	41.0%
Shor-vulnerable (existential break under a CRQC)	28.2%
Grover-weakened (margin reduction only)	5.1%
Already classically broken/deprecated	25.6%

Prioritised migration plan

#	Algorithm	Threat	Count	Exposure	Lifetime	Score	Replacement
1	MD5 `MD5`	CLASSICAL_BROKEN	3	internet_facing	15y	324.4	SHA-256 / SHA3-256 (or SHA-384 for CNSA 2.0)
2	ECB mode (misuse) `MODE-ECB`	CLASSICAL_BROKEN	2	internet_facing	15y	321.3	AES-256-GCM (AEAD)
3	X25519 `X25519`	SHOR	4	internal	7y	255.8	Hybrid X25519MLKEM768 now, ML-KEM-768 later
4	Ed25519 `ED25519`	SHOR	2	internal	7y	250.9	ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
5	AES (key size unknown) `AES-UNK`	GROVER	2	internet_facing	15y	137.7	Verify key size; use AES-256
6	RSA (size unknown) `RSA-UNK`	SHOR	2	internal	1y	84.5	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
7	DH/FFDH (<2048-bit) `DH-SUB2048`	SHOR	1	internal	1y	83.6	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first; stop using <2048 now
8	RSA-2048 `RSA-2048`	SHOR	1	internal	1y	83.6	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
9	RSA-3072 `RSA-3072`	SHOR	1	internal	1y	83.6	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
10	SHA-1 `SHA1`	CLASSICAL_BROKEN	3	internal	2y	64.9	SHA-256 / SHA3-256 (or SHA-384 for CNSA 2.0)

#	Algorithm	Threat	Count	Exposure	Lifetime	Score	Replacement
11	3DES `3DES`	CLASSICAL_BROKEN	1	internal	1y	63.6	AES-256-GCM
12	DES `DES`	CLASSICAL_BROKEN	1	internal	1y	63.6	AES-256-GCM
13	Hybrid KEM (classical+ML-KEM) `HYBRID-KEM`	HYBRID	4	internet_facing	15y	46.8	Later: pure ML-KEM where policy allows
14	ML-DSA (44/65/87) `ML-DSA`	PQ_SAFE	5	internet_facing	15y	18.9	none needed
15	TLS 1.3 (hybrid PQ key exchange configured) `TLS1.3-HYBRID`	HYBRID	2	internal	1y	9.2	none needed -- verify the hybrid group is actually negotiated, not just configured
16	SHA-256 `SHA-256`	PQ_SAFE	2	internal	7y	6.1	none needed
17	ChaCha20(-Poly1305) `CHACHA20`	PQ_SAFE	2	internal	1y	3.7	none needed
18	AES-256 `AES-256`	PQ_SAFE	1	internal	1y	3.6	none needed

Detail per item

1. MD5 (MD5) — *score 324.4*

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 3

Affected components: legacy-batch, payments-svc

Recommended replacement: SHA-256 / SHA3-256 (or SHA-384 for CNSA 2.0)

Locations: demo-run/workdir/web-service/crypto-utils.js:4, demo-run/workdir/app/payments/service.py:17, demo-run/workdir/app/legacy/hash.py:7

2. ECB mode (misuse) (MODE-ECB) — *score 321.3*

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 2

Affected components: payments-svc

Recommended replacement: AES-256-GCM (AEAD)

Locations: demo-run/workdir/app/api/AuthService.java:17, demo-run/workdir/app/payments/service.py:20

3. X25519 (X25519) — *score 255.8*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 7y, against a ~10y conservative planning horizon.

Occurrences: 4

Affected components: vault-svc

Recommended replacement: Hybrid X25519MLKEM768 now, ML-KEM-768 later

Locations: demo-run/workdir/config/sshd_config:2, demo-run/workdir/config/nginx.conf:4, demo-run/workdir/config/openssl.cnf:6, demo-run/workdir/app/crypto/vault.py:6

4. Ed25519 (ED25519) — *score 250.9*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 7y, against a ~10y conservative planning horizon.

Occurrences: 2

Affected components: vault-svc

Recommended replacement: ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware

Locations: demo-run/workdir/config/sshd_config:5, demo-run/workdir/app/crypto/vault.py:9

5. AES (key size unknown) (AES-UNK) — *score 137.7*

Grover-weakened: effective security roughly halves under a large quantum computer; raise key/output size, no protocol redesign needed.

Occurrences: 2

Affected components: payments-svc, vault-svc

Recommended replacement: Verify key size; use AES-256

Locations: demo-run/workdir/app/crypto/vault.py:12, demo-run/workdir/app/payments/service.py:20

6. RSA (size unknown) (RSA-UNK) — *score 84.5*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 1y, against a ~10y conservative planning horizon.

Occurrences: 2

Recommended replacement: ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware

Locations: demo-run/workdir/config/sshd_config:5, demo-run/workdir/app/api/AuthService.java:6

7. DH/FFDH (<2048-bit) (DH-SUB2048) — *score 83.6*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 1y, against a ~10y conservative planning horizon.

Occurrences: 1

Recommended replacement: ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first; stop using <2048 now

Locations: demo-run/workdir/config/sshd_config:2

8. RSA-2048 (RSA-2048) — *score 83.6*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 1y, against a ~10y conservative planning horizon.

Occurrences: 1

Recommended replacement: ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware

Locations: demo-run/workdir/app/api/AuthService.java:7

9. RSA-3072 (RSA-3072) — *score 83.6*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 1y, against a ~10y conservative planning horizon.

Occurrences: 1

Recommended replacement: ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware

Locations: demo-run/workdir/config/openssl.cnf:2

10. SHA-1 (SHA1) — *score 64.9*

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 3

Affected components: legacy-batch

Recommended replacement: SHA-256 / SHA3-256 (or SHA-384 for CNSA 2.0)

Locations: demo-run/workdir/config/sshd_config:4, demo-run/workdir/app/api/AuthService.java:12, demo-run/workdir/app/legacy/hash.py:4

11. 3DES (3DES) — *score 63.6*

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 1

Recommended replacement: AES-256-GCM

Locations: demo-run/workdir/web-service/crypto-utils.js:12

12. DES (DES) — score 63.6

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 1

Recommended replacement: AES-256-GCM

Locations: demo-run/workdir/app/api/AuthService.java:17

13. Hybrid KEM (classical+ML-KEM) (HYBRID-KEM) — score 46.8

Already hybrid classical+PQ; low urgency, monitor for pure-PQ migration once policy allows.

Occurrences: 4

Affected components: payments-svc

Recommended replacement: Later: pure ML-KEM where policy allows

Locations: demo-run/workdir/config/sshd_config:2, demo-run/workdir/config/nginx.conf:4, demo-run/workdir/config/openssl.cnf:6, demo-run/workdir/app/payments/service.py:14

14. ML-DSA (44/65/87) (ML-DSA) — score 18.9

Already quantum-safe with adequate margin.

Occurrences: 5

Affected components: payments-svc

Recommended replacement: none needed

Locations: demo-run/workdir/certs/modern_service.crt:1, demo-run/workdir/certs/legacy_partner.crt:1, demo-run/workdir/certs/legacy_partner.key:1, demo-run/workdir/certs/modern_service.key:1, demo-run/workdir/app/payments/service.py:10

15. TLS 1.3 (hybrid PQ key exchange configured) (TLS1.3-HYBRID) — score 9.2

Already hybrid classical+PQ; low urgency, monitor for pure-PQ migration once policy allows.

Occurrences: 2

Recommended replacement: none needed -- verify the hybrid group is actually negotiated, not just configured

Locations: demo-run/workdir/config/nginx.conf:3, demo-run/workdir/config/openssl.cnf:5

16. SHA-256 (SHA-256) — score 6.1

Already quantum-safe with adequate margin.

Occurrences: 2

Affected components: vault-svc

Recommended replacement: none needed

Locations: demo-run/workdir/web-service/crypto-utils.js:8, demo-run/workdir/app/crypto/vault.py:17

17. ChaCha20(-Poly1305) (CHACHA20) — score 3.7

Already quantum-safe with adequate margin.

Occurrences: 2

Recommended replacement: none needed

Locations: demo-run/workdir/config/sshd_config:3, demo-run/workdir/config/nginx.conf:5

18. AES-256 (AES-256) — *score 3.6*

Already quantum-safe with adequate margin.

Occurrences: 1

Recommended replacement: none needed

Locations: demo-run/workdir/config/sshd_config:3